

SOH 사전 요청 자료 작성안

작성 기준: 2026-09-17 / 기업 확인 전 초안

원본 「사전 요청 자료 목록(기업 작성용)」의 1~51번에 대응하는 답변입니다. 좁은 원본 입력란에 옮겨 쓰거나 별지로 사용할 수 있도록 구성했습니다. 별도 서식 1·2·3·5·6·7은 제공되지 않아 해당 항목의 기초 내용을 작성했습니다. 공식 서식 작성 완료나 증적 제출 완료를 뜻하지 않습니다.

확인 범위는 SOH 백엔드 코드·README·인프라 설정 및 프론트엔드 지침·관리자 메뉴입니다. 운영 서버, DB, 체인 및 외부 제공사 시스템은 조회하지 않았습니다. 따라서 '코드 확인'은 운영 적용·보안 통제의 효과 검증을 뜻하지 않으며, '확인 필요'는 '미보유'나 '아니오'를 뜻하지 않습니다. 코드에 존재하는 연동 API와 실제 사용하는 기능도 구분했습니다.

기본 정보 · 1~6

1. 조직도

기업 확인 필요. 조직도에 개인정보보호책임자(CPO), 정보보호 담당 직위·부서 및 개인정보 취급 부서를 표시하여 별도 제출해야 합니다. 개발 저장소로 조직과 책임자를 확인할 수 없습니다.

2. 임직원 수

기업 확인 필요. 정규직 []명, 비정규직 []명, 총 []명.

3. 개발자·기술 인력 수

기업 확인 필요. 블록체인 []명, 백엔드 []명, 프론트엔드 []명, 인프라·운영 []명. 겸직 인원은 중복 집계 여부를 명시해야 합니다.

4. 보안 전담 인력 수

기업 확인 필요. 전담 []명, 겸직 []명, 겸직 담당 직무 [].

5. 정보보호·개인정보보호 담당자 유무

기업 확인 필요. 지정 여부 [], 담당 직위·부서 [].

6. 24×7 운영·관제 여부

기업 확인 필요. 클라우드 상시 가동 구성과 24시간 인력 관제는 별개입니다. 교대 관제, 외부 관제 계약 및 비상 연락 체계는 저장소에서 확인되지 않았습니다.

서비스·기술 구성 · 7~14

7. 블록체인 서비스 개요

서비스명: SOH(Senior Oral Healthcare), 시니어 구강건강 관리 서비스.

구강체조 콘텐츠와 진도 관리, 구강 이미지 기반 치태·치은염 분석, 설문 및 맞춤 콘텐츠를 제공하며, DaeguChain·다대구 연동을 통해 DID 기반 사용자 연계와 지갑 관리, 구강체조 리워드 토큰 지급·회수 기능을 구현했습니다. 관리자 기능에는 사용자·진도·리워드 현황 및 블록체인 연동 로그 조회가 포함됩니다. 상품 수령 단계에는 리워드 회수 처리가 연계됩니다.

서비스 URL: <https://soh.thomabio.com> / API: <https://api.soh.thomabio.com/api>. 확인 자료는 README, 구강체조·리워드·다대구 연동 소스 및 관리자 화면입니다. 출시일 [기업 확인 필요], 실제 사용자 수 [기준일과 함께 기업 확인 필요].

8. 블록체인 유형

DaeguChain 및 외부 DID·토큰 서비스 API를 이용하는 연동 구조입니다. 퍼블릭·프라이빗·컨소시엄 구분, 기반 플랫폼·버전, 체인 ID와 메인넷·테스트넷 구분은 제공사 확인이 필요합니다. API의 token-20-nft-721 명칭만으로 Ethereum 등 특정 체인으로 확정하지 않았습니다.

9. 서비스 운영 단계

저장소 문서에는 운영 서비스 주소와 prod 배포 체계가 정의되어 있습니다. 다만 실제 운영 상태와 연결 체인의 메인넷 운영 여부는 이번 작성에서 실시간 확인하지 않았으므로, 제출 시 서비스 운영 담당자 및 체인 제공사가 확정해야 합니다.

10. 스마트컨트랙트 운영 여부 및 개수

토큰 생성·조회·전송·회수와 token-20-nft-721 관련 외부 API 연동 코드를 보유합니다. SOH 백엔드 확인 범위에서는 자체 컨트랙트 소스와 컨트랙트 빌드 체계를 확인하지 못했습니다. 실제 배포 컨트랙트 수·주소, 소유·관리 주체, 자체 개발 여부는 별도 확인이 필요합니다. '컨트랙트 0개'로 기입하면 안 됩니다.

11. 지갑·수탁·키 관리 기능

예. DID·리워드 지갑 생성 및 연계, 지갑 주소·리워드 거래 관리, 지갑 개인키 암호화 저장 기능이 구현되어 있습니다. SOH는 서버에서 사용자 지갑 개인키를 취급하는 구조이며, 저장 시 AES-256-GCM을 사용합니다. 토큰 회수 요청은 외부 토큰 서버로 운영자 개인키를 포함한 요청을 전달하며, holder 서명키 해석은 외부 서버에 의존합니다. 실제 서명 환경 및 수탁 책임 구분은 제공사와 확인해야 합니다.

12. 주요 시스템 구성

웹 프론트엔드(React·TypeScript·Vite, S3·CloudFront) → HTTPS API → ALB → 사설 앱 서버넷의 EC2 Auto Scaling Group(Spring Boot·Java 17) → 사설 DB 서버넷의 RDS MySQL 구성입니다. API는 외부 DaeguChain·DID·토큰 서비스와 연동합니다. Secrets Manager는 DB 자격증명 관리에 사용합니다. 서버 실가동 수량과 외부 체인 노드 수는 확인 필요합니다.

13. 클라우드 사용 여부 및 사업자

예. AWS를 사용하며, 백엔드 인프라 기준 리전은 서울(ap-northeast-2)입니다. 저장소상 주요 구성은 EC2, Auto Scaling, ALB, RDS MySQL, S3, CloudFront, VPC, NAT Gateway, IAM, Secrets Manager 등입니다. 개별 리소스의 현재 가동 수량은 별도 확인이 필요합니다.

14. 노드 직접 운영 여부

SOH 저장소의 확인 범위에는 자체 블록체인 노드 배포·운영 구성이 없으며 외부 API 연동 구조입니다. 기업 전체의 별도 노드 보유 여부와 제공사 위탁 운영 여부는 확인 필요합니다. 직접 운영하지 않는 것으로 확정될 경우 '아니오, 외부 제공사 API 이용'으로 기입할 수 있습니다.

개인정보 처리 · 15~18

15. 개인정보 처리 여부

예. 회원가입·로그인, 기관별 사용자 관리, 다대구 인증 연계, 구강건강 서비스와 리워드 제공 과정에서 개인정보를 처리하는 코드가 구현되어 있습니다.

16. 처리하는 개인정보 유형

이름, 전화번호, 생년월일, 성별, 로그인 식별자, 비밀번호 해시, 비밀번호 찾기 질문·답변, 소속 기관, DID, 다대구 CI의 해시, 지갑 주소, 로그인·서비스 이용 기록, 구강체조 진도·리워드 거래 기록 등을 처리합니다. 구강 이미지, 치태·치은염 분석 결과, 설문 응답 등 건강 관련 정보도 처리 대상입니다. 구강 이미지를 신원 식별용 생체정보로 사용한다고 확인된 것은 아닙니다. 항목별 보유기간·법적 분류·제3자 제공 범위는 실제 처리방침과 대조해야 합니다.

17. 개인정보 처리방침

최신 승인본과 게시 URL 확인 필요. 서비스 주소는 <https://soh.thomabio.com> 이지만 이를 개인정보 처리방침 전용 URL로 대체할 수는 없습니다. 개인정보·건강정보·DID·지갑정보 처리, 외부 연동, 보유기간 및 파기 내용을 반영한 최신 원문을 기업에서 별도 제출해야 합니다.

18. 만 14세 미만 아동 대상 여부

서비스는 시니어 구강건강 관리를 목적으로 합니다. 그러나 목적만으로 아동 이용 배제를 확정할 수 없으므로 실제 가입 정책·연령 제한과 법정대리인 동의 운영 여부를 기업에서 확인해야 합니다.

정보보호 관리체계 · 19~22

19. 정보보호 정책·지침 보유 여부

개발·운영 지침(AGENTS.md, README)에 비밀값 기록 금지, DB 자격증명 관리, 운영 배포 통제, 지갑 암호화 키 보존 등의 규칙이 있습니다. 전사 승인된 정보보호·개인정보보호 정책의 존재와 문서명·승인일은 기업 확인 필요합니다. 개발 지침을 전사 정책과 동일시하지 않았습니다.

20. 최근 1년 취약점 점검

기업 확인 필요. 코드의 보안 헤더나 테스트 존재만으로 공식 취약점 점검 수행을 입증할 수 없습니다. 수행 기관·기간·범위·결과 보고서 및 조치 내역이 필요합니다.

21. ISMS·ISO27001 등 인증

기업 확인 필요. 인증명, 인증 범위, 유효기간 및 증빙 원본을 기준으로 작성해야 합니다.

22. 최근 3년 보안사고

기업 확인 필요. 사고 유무는 운영·보안 책임자의 확인과 사고대장에 근거해야 하며, 저장소에서 확인되지 않았다는 이유로 '없음'으로 기입하지 않습니다.

블록체인 점검 · 23~47

23. 블록체인 보안현황 조사서

서식1 미제공으로 공식 조사서 작성 대기. 본 문서 7~16번과 24~46번을 기초 답변으로 사용할 수 있습니다. 외부 제공사 운영 영역과 SOH 개발·운영 영역을 구분하여 점검 범위를 확정해야 합니다.

24. 점검 대상 목록

웹: <https://soh.thomabio.com>. API: <https://api.soh.thomabio.com/api>. 관리자 화면: 사용자·진도·DID/리워드·연동 로그·토큰 관리 기능. 백엔드: 구강체조 리워드 지급·회수, 지갑·DID 연계, 다대구 로그인, 관리자 토큰 생성 및 범용 DaeguChain API.

지갑: 사용자 리워드 지갑과 토큰 운영자 지갑. 컨트랙트: 실제 사용 토큰명·컨트랙트 주소·체인 식별정보 확인 필요. 노드: 외부 연동 대상이며 운영 방식·대수 확인 필요. 서식2에는 활성 기능과 비활성·미사용 연동 API를 구분하고 실제 주소를 검증한 후 기입해야 합니다.

25. 아키텍처·설계 자료

보유 근거는 README와 infra/terraform, API 소스입니다. 서비스 흐름은 웹 → SOH API → DB 및 외부 DID·토큰 API입니다. 오프체인 처리에는 회원정보, 건강정보, 진도, 암호화된 지갑 개인키, 리워드 처리 상태와 연동 로그가 포함됩니다. 온체인 연계 대상은 토큰 컨트랙트·주소·전송 결과입니다. DID·VC의 실제 체인 기록 범위와 외부 서버 저장 범위는 제공사 확인 필요입니다.

회원·건강정보가 전부 온체인에 기록된다고 볼 근거는 없습니다. 반대로 외부 서비스까지 개인정보 온체인 기록이 전혀 없다고 보장할 근거도 없습니다. 외부 API 성공 응답 및 계약한 주소·토큰 매핑을 신뢰하는 경계가 있으므로 체인 확정 기준은 별도 명세가 필요합니다.

26. 불변식·파라미터 명세

자체 컨트랙트 명세는 확인되지 않았습니다. 참고 가능한 SOH 백엔드 제약은 사용자·토큰별 기준 지급 확인 및 idempotency key 사용, 완료된 리워드 여정의 추가 지급 차단, 실패 지급의 잔액 미반영, 성공 회수의 중복 처리 방지, 회수 결과에 따른 초기화·삭제 보호입니다. 이는 컨트랙트 차원의 불변식이나 분산 시스템 전체의 정확히 한 번 실행 보장을 뜻하지 않습니다.

코드상 필수 회수 리워드 기준은 5개이며 지급량은 설정값을 사용합니다. 지갑 암호화는 32바이트 키, 12바이트 무작위 IV, 128비트 인증 태그입니다. 토큰 전송 API 경로와 생성 API 경로가 동일하면 거부합니다. 실제 운영 지급량과 컨트랙트 파라미터의 범위·설정 근거는 별도 확인이 필요합니다.

27. 스마트컨트랙트 소스코드

SOH 백엔드는 Java 서비스로, 확인 범위에서 자체 컨트랙트 소스·컴파일러 설정·컨트랙트 의존성 lockfile을 확인하지 못했습니다. 외부 제공사 또는 별도 블록체인 저장소의 소유 주체에 확인해야 합니다. SOH API 소스를 컨트랙트 소스 제출물로 대신 표시하지 않습니다. 백엔드 검토 기준 커밋은 문서 말미에 기재했습니다.

28. 배포 스크립트·설정

SOH API의 배포 자료는 .github/workflows/deploy-api-prod.yml 및 infra/terraform입니다. 이는 애플리케이션·클라우드 배포 자료이며 컨트랙트 배포 스크립트는 아닙니다. 자체 컨트랙트가 확인되면 해당 배포 순서·초기 파라미터·검증·롤백 자료를 별도로 받아야 합니다.

29. 권한 구조 문서

SOH API는 JWT와 역할 기반 접근 통제를 사용합니다. /daegu-chain/**는 SUPER_ADMIN, /admin/**는 기본적으로 ADMIN 또는 SUPER_ADMIN 접근이며, 관리자 삭제·비밀번호 초기화·목록 등 일부 기능은 SUPER_ADMIN으로 제한합니다. 사용자 API는 로그인 사용자 문맥을 사용합니다. 세부 기능은 서비스 계층의 기관·사용자 범위 검사를 함께 확인해야 합니다.

컨트랙트 소유자·다중서명 서명자·임계값·타임락은 이 API 역할과 별개이며 확인 필요입니다. 서식6에는 API 역할과 온체인 권한을 나누고, 실제 권한 계정·부여 및 회수 절차를 추가해야 합니다.

30. 업그레이드 절차

컨트랙트 프록시 구조·업그레이드 권한·스토리지 충돌 검증은 확인 필요입니다. SOH API의 CI/CD 및 EC2 교체 배포를 컨트랙트 업그레이드 절차로 대신 제출할 수 없습니다. 비업그레이드 구조가 확인되면 해당 없음으로 처리할 수 있습니다.

31. 외부 의존성 현황

DaeguChain API: 계정·DID·토큰 등 연동에 사용. 잘못된 주소·조화·처리 결과는 지갑 연결이나 거래 상태 오인에 영향을 줄 수 있습니다. 실제 운영 주체·계약 범위·대체 엔드포인트 확인 필요.

외부 토큰 서버: 토큰 생성·목록·지급·회수 및 회수 시 holder 서명키 해석에 의존. 실패하면 지급·회수 완료 처리에 영향을 줍니다. 코드에는 특정 DID 미발견 오류에 최대 3회, 700ms 간격의 재시도가 있으며 독립 대체 제공사로 전환하는 경로는 확인되지 않았습니다.

다대구 인증·외부 DID 서비스: 인증 결과와 DID 발급에 의존. 장애 시 해당 연동 경로 이용이 제한될 수 있습니다. 일반 ID·비밀번호 로그인도 존재하지만 모든 사용자의 자동 대체 인증 경로를 보장하지 않습니다. 외부 제공사의 법인명·지원 청구·SLA는 기업 확인 필요입니다.

AWS: 웹·API·DB·비밀정보 저장 등 서비스 인프라에 사용. 장애 전환 구성·복구목표·복구시험 기록은 별도 확인 필요입니다. 서식5가 제공되면 의존 대상별로 이 내용을 이관할 수 있습니다.

32. 노드 설정 자료

SOH 확인 범위에서는 직접 운영 노드 설정을 확인하지 못했습니다. 외부 제공사의 노드 클라이언트·버전, RPC 노출, P2P 구성 및 검증자 키 관리 자료가 필요합니다. 기업의 직접 운영 여부가 확정되기 전에는 '해당 없음'으로 단정하지 않습니다.

33. 폐쇄형·자체 체인 자료

체인 유형·운영 주체 확인 후 적용 여부를 확정해야 합니다. SOH 저장소에서 genesis/chainspec, 합의·채널·MSP·CA·보증 정책 등 체인 운영 자료는 확인되지 않았습니다. 폐쇄형 체인이라면 제공사 보유 자료를 요청해야 합니다.

34. 지갑 구성 자료

사용자 리워드 지갑: DID·사용자와 연결되며 주소 및 암호화 개인키를 서버 DB에 관리하는 구조입니다. 토큰 운영자 지갑: 지급·회수 업무에 사용되는 운영자 주소·개인키 설정이 존재합니다. 외부 토큰 서버가 수행하는 실제 서명 환경과 키 조화 범위는 별도 확인이 필요합니다.

핫·웜·콜드 분류, 실제 주소 목록, 중요도, 키 관리자 직무, 벤더 계약 주체는 미확정입니다. 서식7에는 공개 주소만 검증 후 기입하고 개인키·복호화 키는 넣지 않아야 합니다. 서버 온라인 처리 구조는 확인되지만 콜드월렛·HSM·MPC 사용을 확인한 것은 아닙니다.

35. 키 관리 정책·절차

구현 확인: 지갑 개인키는 AES-256-GCM으로 암호화하며 매 암호화 시 SecureRandom으로 IV를 생성합니다. 암호화 키는 서버 설정으로 공급하고, 값이 없거나 길이가 올바르지 않으면 처리에 실패합니다. DB 자격증명은 RDS managed Secret과 Secrets Manager JDBC 연동을 사용하도록 운영 지침에 정의되어 있습니다.

미확인: 지갑 키 생성기의 엔트로피, 입회·승인 기록, HSM/KMS/MPC 적용, 키 백업·분산 보관, 복구 시험, 정기 교체, 폐기·매체 삭제 절차. AES 암호화 구현과 DB Secret 사용만으로 지갑 키가 HSM/KMS에 보관된다고 작성할 수 없습니다. 기존 지갑 암호화 키는 임의 교체하면 복호화에 영향을 주므로 별도 이관·복구 절차가 필요합니다.

36. 키 사용·서명 통제

확인한 제어는 JWT·역할 기반 접근, 사용자별 리워드 상태와 중복 검사, 지갑 및 운영자 설정 검사, 외부 요청 결과에 따른 성공·실패 처리입니다. 토큰 회수 API는 운영자 개인키를 외부 서버 요청 본문에 포함합니다. 일부 범용 블록체인 API도 키를 취급하므로 점검 범위에 포함해야 합니다.

금액 한도, 출금 주소 화이트리스트, 시간대 제한, 다중 승인, 전용 서명 단말, 독립 검증 화면 및 별도 승인 채널은 확인 필요입니다. 애플리케이션 JWT 인증을 트랜잭션별 다중 승인으로 간주하지 않습니다.

37. 키 침해 대응

공식 키 침해 대응 정책, 긴급 자산 이전 절차, 역할·연락망 및 시험 기록은 확인 필요입니다. 현재 문서에서 보유 여부를 확정할 수 없습니다. 운영 담당자와 외부 토큰·DID 제공사가 보유한 절차를 확인하여 제출해야 합니다.

38. 온체인 연계 백엔드 자료

주요 API(아래 경로 앞에 /api 적용): GET /user/rewards/wallet, POST /user/rewards/wallet/connect, GET /user/rewards/transactions, POST /oral-exercise/rewards/button-click, POST /oral-exercise/rewards/reclaim, POST /login/dadaegu, POST /admin/daegu-chain/token/create. 범용 관리자 연동은 /daegu-chain/common/account, /token-20, /nft-721, /point, /did, /timestamp 등으로 구성됩니다. 뒤의 단축 경로들은 모두 /daegu-chain 하위입니다.

지급 흐름: 사용자 인증 → 요청·콘텐츠·토큰 식별 확인 → 기존 지급 및 먹등키 조회 → 리워드 여정 완료 여부 확인 → 지급·거래 기록 준비 → 설정에 따른 외부 토큰 전송 또는 포인트 처리 → 결과 상태 기록 → 성공한 리워드만 내부 잔액 반영. 외부 실패는 오류·실패 상태로 다루며, 토큰 전송 실패 기록은 재시도 분기가 존재합니다.

회수 흐름: 사용자 상품 수령 요청 또는 관리자 초기화·삭제 업무 → 회수 대상 및 기존 완료 회수 검사 → 지급·운영자 설정·토큰 주소 확인 → 외부 토큰 서버 회수 요청 → 성공·실패 기록 및 잔액·여정 처리. 초기화·삭제는 회수 실패를 무시하지 않는 보호 흐름을 포함합니다. 사용자 수령과 관리자 초기화·삭제는 서로 다른 진입 경로입니다.

자산 이동·발행을 발생시킬 수 있는 코드상 점검 경로: 구강체조 지급, 상품 수령 회수, 관리자 사용자 초기화·삭제 시 회수, 관리자 토큰 생성, 범용 계정 transfer-faucet, token-20 create-mint-burn-approve-transfer-transfer-from, NFT 생성·발행·승인·전송, point 생성·발행·전송. 실제 활성 상태와 외부 효과를 제공사와 대조해야 하며 지급 버튼만 점검 대상으로 삼으면 안 됩니다.

입금 확정·재구성: 리워드 지급 결과를 내부 기록에 반영하는 코드는 있지만, 일반 입금 감시·확정 블록 수·체인 재구성 시 롤백을 수행하는 독립 인덱스 구성은 확인되지 않았습니다. 외부 성공 응답을 체인 최종 확정과 동일하게 간주할 수 없으며, 전송 성공 후 응답 유실·타임아웃 시 재처리 기준도 제공사와 확인해야 합니다.

서명 서버: SOH API가 외부 토큰·체인 API로 요청을 전달하는 경계까지 확인했습니다. 실제 서명 프로세스 격리·접근 계정·권한은 제공사 확인 대상입니다. SOH 측 거부 조건에는 인증·역할 미충족, 누락된 지급·운영자 설정, 유효하지 않은 요청, 완료된 리워드 여정, 잘못된 전송 경로 설정 등이 있습니다.

인증 콜백: 다대구 암호화 인증 결과를 서버 RSA 키로 복호화하고 필수 정보·형식을 처리하며 CI는 해시로 저장하는 구현입니다. 암호문 복호화 자체가 발신자 서명 검증이나 재전송 방지를 보장하지 않으므로 해당 요건은 연동 명세와 추가 대조해야 합니다. 블록체인 거래 웹훅 검증 체계는 확인되지 않았습니다.

39. 관리자 콘솔

프론트엔드 관리자 메뉴에는 /admin/users, /admin/exercise-progress, /admin/daegu-reward-status, /admin/daegu-chain-usage-logs, /admin/token-management 등이 있습니다. 메뉴 표시와 서버 인가는 별도로 적용되며 서버 역할 제약은 29번을 참고합니다. 로그인은 계정 인증 및 JWT 기반입니다. MFA 적용 여부, 실제 운영 계정 목록, 계정별 권한과 퇴직·직무변경 시 회수 내역은 기업 확인 필요입니다.

40. 프론트엔드·앱 설정 및 서명 화면

React·TypeScript 웹 프론트엔드와 SOH API를 통한 리워드 처리 구조를 확인했습니다. 현재 확인 범위에서는 사용자 브라우저 지급의 독립 서명 승인 화면, 직접 RPC 접속 및 모바일 개인키 보관을 확정하지 못했습니다. 프론트엔드·앱의 실제 배포 설정에서 체인 ID·컨트랙트 주소·RPC 사용 여부를 확인하고 상품 수령·리워드 승인 화면을 증적으로 제출해야 합니다. SOH 서버 개인키 취급을 모바일 개인키 보관으로 기재하지 않습니다.

41. 온체인 모니터링

외부 체인 API 요청·응답·성공 여부를 기록하는 감사 로그와 관리자 조회 기능이 있습니다. 민감 필드 마스킹 구현을 포함합니다. 다만 이것은 온체인 이벤트 전용 감시와 동일하지 않습니다. 감시 주소·특권 함수 탐지·이상 거래 임계값·담당자 알림 및 대응 시한은 별도 확인 필요합니다.

42. 긴급 정지 및 사고 이력

공식 출금·컨트랙트 긴급 정지 절차, 발동 기준·승인 권한·소요시간과 사고·장애 대장은 확인 필요입니다. 리워드 설정의 token-transfer-enabled 분기에서는 토큰 전송 대신 포인트 처리로 이어질 수 있으므로 단순 설정 변경을 모든 보상·자산 이동의 긴급 정지 기능이라고 볼 수 없습니다. 범용 관리자 API와 외부 제공사 경로까지 포함한 정지 범위를 확정해야 합니다.

43. 기존 감사·점검 자료

스마트컨트랙트 감사 보고서, 블록체인 보안점검 결과, 미조치 내역의 보유 여부는 기업·제공사 확인 필요입니다. 개발 테스트나 보안 관련 코드 주석은 독립 감사 보고서를 대체하지 않습니다.

44. 온체인 잔액·내부 원장 대사

내부 리워드 거래의 지급·회수 상태로 잔액을 재계산하는 구현은 있습니다. 이는 온체인 전체 잔액과의 정기 대사 절차를 입증하지 않습니다. 결제·정산 서비스 해당 여부를 먼저 확인하고, 해당하면 대조 주기·최근 실행 기록·불일치 처리 절차를 제출해야 합니다. 구강체조 리워드와 일반 결제·정산 업무를 구분해야 합니다.

45. 증적 표본

이번 작성에서는 운영 거래·DB·로그를 추출하지 않았습니다. 점검 수행사가 지정한 리워드 지급·회수 사례에 대해 요청, 인증 주체, 처리 상태, 외부 응답, 거래해시, 내부 잔액 반영을 연결하여 제출할 수 있도록 준비해야 합니다. 감사·승인·온체인 해시가 실제 기록되지 않은 경우 기록이 있는 것처럼 작성하면 안 됩니다. 권한 변경·키홀더 변경·알림 대응 사례도 보유 여부를 먼저 확인하고 개인정보와 비밀값을 마스킹해야 합니다.

46. 점검 환경·접근권

SOH 백엔드 검토 대상은 Senior-Oral-Healthcare-api 저장소이며 기준 커밋은 문서 말미와 같습니다. 읽기 전용 접근권 또는 검증된 소스 스냅샷 제공 방식으로 협의할 수 있습니다. 이번 작업에서 접근권을 부여하거나 외부로 소스를 전송하지 않았습니다. 폐기된 AWS dev 환경을 테스트넷 제공 환경으로 기입하지 않아야 하며, 테스트 체인·포크 환경은 별도 확인해야 합니다.

47. 자료반출 구분표

서식3 작성 기초안: README·아키텍처 설명·비밀값을 제거한 설정·API 목록·마스킹한 증적은 반출 검토 대상으로, 실제 개인키·암호화 키·JWT secret·DB 비밀번호·API 토큰·개인정보 원문은 반출 제외 대상으로 분류할 수 있습니다. 민감 설정·운영 계정 상세는 현장 열람 또는 마스킹 사본으로 대체하는 방식을 협의할 수 있습니다. 이는 제안이며 기업의 승인된 반출 정책으로 확정된 것은 아닙니다.

정보시스템 점검 · 48~51

48. 주요 시스템 상세정보

서버: Amazon Linux 2023 기반 EC2 Auto Scaling 구성, Java 17. 실제 EC2 수량 확인 필요. 운영 Windows 서버는 확인 범위에서 식별되지 않았습니다.

DBMS: RDS MySQL 구성. 저장소 지침의 운영 승인 버전은 8.4.10이며 실제 적용 버전·인스턴스 수는 별도 확인 필요.

웹 서비스: Spring Boot 3.5.16과 starter-web 기반 내장 서블릿 컨테이너 구조. 실제 Tomcat 버전은 배포 산출물 의존성 기준 확인 필요. 독립 Apache·Nginx·IIS 운영 여부와 수량은 확인 필요.

보안·네트워크: VPC, 서브넷, Security Group, ALB, NAT Gateway, S3 Gateway Endpoint 등 AWS 구성.

WAF·VPN·IDS·IPS 및 별도 네트워크 장비 수량은 확인 필요이며 Security Group을 전용 보안장비 수량으로 환산하지 않습니다.

가상화: AWS 관리 인프라를 이용합니다. 자체 ESXi·vCenter·KVM 등 관리 장비 보유 여부는 확인 필요. 클라우드: AWS, 서비스 종류는 13번 참조. 모든 수량은 운영 인벤토리로 확정해야 합니다.

49. 정보시스템 점검 스크립트 결과

점검기관 스크립트·가이드가 제공되지 않아 미실행입니다. 자료 제출 안내만으로 운영 서버에서 스크립트를 실행하지 않았습니다. 후속 파일 수신 후 실행 범위·권한·부작용을 확인하여 결과를 수집해야 합니다.

50. 네트워크 장비 Config

직접 운영 네트워크 장비와 제출 대상 확인 필요. AWS 네트워크의 경우 민감값을 제거한 VPC·라우팅·Security Group 등 구성 자료를 대체 제출할 수 있는지 점검기관과 협의할 수 있습니다. 실제 운영 설정을 이번 작업에서 수집하지 않았습니다.

51. 보안장비 사전 질의

후속 질의 파일 및 실제 보안장비 인벤토리 확인 필요. 본 문서의 AWS 네트워크·접근 제어 내용은 기초 답변으로 활용 할 수 있으나, 장비별 설정·수량·운영 책임자는 별도 작성해야 합니다.

작성 근거와 검증 기록

- 기준 백엔드 커밋: 32877be1e467b2a2937ce4252bca0cc1161cda2d, 로컬 prod 브랜치. 프론트엔드 확인 기준: 016beb90eeeece00add657dc40b7ed0aab39c017.
- 서비스·인프라: README.md, AGENTS.md, api_server/build.gradle, infra/terraform, .github/workflows/deploy-api-prod.yml. 프론트엔드 AGENTS.md 및 src/components/layouts/admin/AdminSidebar.tsx.
- 권한: api_server/src/main/java/com/kaii/dentix/global/config/WebSecurityConfig.java.
- 사용자 정보·인증: 같은 Java 루트의 domain/user/domain/User.java, DadaeguUserIdentity.java 및 domain/user/application/DadaeguLoginService.java.
- 지갑·외부 경계: domain/daeguChain/application/DaeguWalletPrivateKeyCipher.java, DaeguChainApiAuditService.java, domain/daeguChain/client/ExternalTokenClient.java 및 domain/daeguChain/controller.
- 지급·회수: domain/reward/application/UserRewardService.java, UserRewardReclaimService.java, domain/reward/controller/UserRewardController.java, domain/oralExercise/controller/OralExerciseController.java, domain/admin/controller/AdminUserController.java 및 AdminDaeguChainTokenController.java.
- 환경·영향: 문서 작성만 수행. API·DB·Secret·인프라 변경 없음. 운영 접속·거래 실행·자료 이메일 발송 없음. README와 AGENTS.md는 관련 사실 변경이 없어 수정하지 않음.
- 검증: 원본 3페이지 확인, 1~51번 대응 및 코드 근거 검토. 앱 빌드·테스트는 문서 작업이므로 생략. 제출 전 기업·제공사 확인이 필요한 항목은 본문에 명시.
- 남은 제한: 현행 운영 설정·통제 효과·정책 승인·실거래 증빙은 미검증. '확인 필요'를 제출 직전 확정해야 함.
- 롤백: 이번 작성안 파일을 제거하거나 문서 커밋만 되돌리면 됨. 기존 사용자 자료와 원본 PDF는 보존.